Đề bài: Defense in Depth cho AuthN/AuthZ – LMS (Flask)

Oct 19, 2026 · @Bui Duc Trung

Thời gian: 35 phút · **Stack:** Python 3.11+, Flask 3.x · **Chấm:** trực tiếp với giảng viên

Nhiệm vụ: Xây module xác thực và phân quyền cho LMS gồm 4 endpoint. Các lớp bảo vệ phải độc lập: gỡ một lớp thì lớp khác vẫn chặn được tấn công.

Gợi ý thời gian: 0–5′ dựng project · 5–13′ lớp 1 · 13–18′ lớp 2–3 · 18–28′ lớp 4–6 · 28–35′ lớp 7–8.

1. Yêu cầu kỹ thuật

- Dữ liệu nạp từ `seed.json` vào bộ nhớ, không dùng database.
- Được dùng: `bcrypt` hoặc `argon2-cffi`, `PyJWT`, `pydantic` (tuỳ chọn).
- Cấm: Flask-Login, Flask-JWT-Extended, Flask-Security, Flask-HTTPAuth, Authlib.
- `app/__init__.py` có `create_app(config=None)`. Mỗi lần gọi nạp lại seed và tạo state mới; `config` ghi đè biến môi trường.
- Chạy: `pip install -r requirements.txt` rồi `flask --app app run`.

Cấu hình	Mặc định	Yêu cầu
`JWT_SECRET`	—	Bắt buộc, ≥ 32 ký tự. Thiếu thì `create_app()` ném `RuntimeError`.
`TOKEN_TTL_SECONDS`	900	
`AUDIT_LOG_PATH`	`audit.log`	

Cấu trúc bắt buộc:

```
app/
  __init__.py   create_app()
  store.py      nạp seed.json
  auth.py       băm mật khẩu, ký/xác minh token, login   (lớp 1, 7)
  gate.py       before_request mặc định từ chối          (lớp 2)
  guards.py     decorator @require_role(*roles)          (lớp 3)
  services.py   get_grades(actor, course_id)             (lớp 4)
                update_grade(actor, course_id, student_id, score)
  schemas.py    validate body                            (lớp 5)
  errors.py     Forbidden, NotFound, ValidationError,    (lớp 6)
                error handler trả JSON
  audit.py      ghi audit log                            (lớp 8)
seed.json
requirements.txt
```

`actor` là dict user `{"id", "email", "role"}`. `services.py` không import `flask`, tự ném exception từ `app.errors`.

2. Dữ liệu seed

Mật khẩu chung `Lms@2026`, phải băm khi nạp và không giữ bản rõ. u2 dạy c1, u3 dạy c2, u6 không học c1.

```
{
  "users": [
    { "id": "u1", "email": "admin@lms.test",   "password": "Lms@2026",
"role": "ADMIN" },
    { "id": "u2", "email": "an.gv@lms.test",   "password": "Lms@2026",
"role": "INSTRUCTOR" },
    { "id": "u3", "email": "binh.gv@lms.test", "password": "Lms@2026",
"role": "INSTRUCTOR" },
    { "id": "u4", "email": "chi.sv@lms.test",  "password": "Lms@2026",
"role": "STUDENT" },
    { "id": "u5", "email": "dung.sv@lms.test", "password": "Lms@2026",
"role": "STUDENT" },
    { "id": "u6", "email": "em.sv@lms.test",   "password": "Lms@2026",
"role": "STUDENT" }
  ],
  "courses": [
    { "id": "c1", "title": "Lập trình Web", "instructorId": "u2" },
    { "id": "c2", "title": "Cơ sở dữ liệu", "instructorId": "u3" }
  ],
  "enrollments": [
    { "courseId": "c1", "studentId": "u4", "score": 7.5 },
    { "courseId": "c1", "studentId": "u5", "score": 8.0 },
```

```
    { "courseId": "c2", "studentId": "u5", "score": 6.0 },
    { "courseId": "c2", "studentId": "u6", "score": 9.0 }
  ]
}
```

3. API

JSON vào ra; token gửi qua `Authorization: Bearer <token>`. Mọi lỗi trả `{"error": "<MÃ>"}`, kể cả 404/405 mặc định của Flask.

Endpoint	Thành công
`POST /auth/login`, body `{email, password}`	200 `{accessToken, expiresIn}`
`GET /me`	200 `{id, email, role}`
`GET /courses/<course_id>/grades`	200 `[{studentId, score}]`
`PUT /courses/<course_id>/grades/<student_id>`, body `{score}`	200 `{courseId, studentId, score}`

Người gọi	GET điểm của môn	PUT điểm
ADMIN	Toàn bộ	403
GV dạy môn	Toàn bộ	Được, nếu SV có ghi danh
GV khác	403	403
SV có ghi danh	Chỉ dòng của mình	403
SV không ghi danh	403	403

HTTP	`error`	Khi nào
400	`VALIDATION_ERROR`	Body sai kiểu, `score` ngoài [0, 10], có field thừa
401	`INVALID_CREDENTIALS`	Login sai; email không tồn tại và sai mật khẩu trả giống hệt
401	`UNAUTHENTICATED`	Thiếu, sai hoặc hết hạn token; user trong token không còn
403	`FORBIDDEN`	Không đủ quyền

HTTP	`error`	Khi nào
404	`NOT_FOUND`	Route hoặc môn không tồn tại; SV không ghi danh (PUT)
429	`ACCOUNT_LOCKED`	Tài khoản bị khoá tạm
500	`INTERNAL_ERROR`	Lỗi bất ngờ, không lộ stack trace

- Thứ tự kiểm tra: 401 → 404 (môn) → 403 → 400 → 404 (ghi danh).
- JWT HS256 chỉ chứa `sub`, `iat`, `exp`. Role và quan hệ môn học tra từ store ở mỗi request.

4. Các lớp bảo vệ

Lớp 1–6 bắt buộc, lớp 7–8 mở rộng.

Lớp	Yêu cầu
1. Xác thực (`auth.py`)	Băm bcrypt (cost ≥ 10) hoặc argon2. JWT HS256 có `exp`; `jwt.decode` phải truyền `algorithms=["HS256"]`. Login sai trả phản hồi giống nhau.
2. Mặc định từ chối (`gate.py`)	`before_request` toàn cục: mọi request cần token hợp lệ, trừ allowlist duy nhất `POST /auth/login`. Route mới không khai báo vẫn được bảo vệ.
3. Vai trò (`guards.py`)	`@require_role(...)` trên từng route; sai vai trò trả 403.
4. Quyền trên đối tượng (`services.py`)	Service tự kiểm tra theo ma trận quyền, không dựa vào lớp 3. Gọi trực tiếp với actor sai phải ném `Forbidden`.
5. Đầu vào (`schemas.py`)	`score` là số trong [0, 10]; từ chối `"10"`, `true`, field thừa. Service kiểm tra lại miền giá trị.
6. Đầu ra, fail closed (`errors.py`)	Chỉ trả field trong contract. Mọi lỗi trả JSON, không stack trace. Thiếu `JWT_SECRET` thì không tạo app.
7. Brute-force (`auth.py`)	Sai 5 lần liên tiếp cùng email: khoá 15 phút, trả 429 kể cả khi đúng mật khẩu. Đăng nhập đúng trước ngưỡng thì reset.

Lớp	Yêu cầu
8. Audit (`audit.py`)	Mỗi lần sửa điểm và mỗi lần 403 ghi một dòng JSON: `ts, actorId, action, resource, result`, kèm điểm cũ/mới khi sửa. Không ghi mật khẩu, token.

Khi chấm, giảng viên sẽ gỡ `@require_role` khỏi route PUT và thêm một route mới không khai báo gì.

5. Kịch bản kiểm tra

Bài phải xử lý đúng các kịch bản dưới; giảng viên chạy trực tiếp khi chấm. A18–A19 thuộc phần mở rộng.

#	Thao tác	Kết quả đúng	Lớp
A1	Login `khongco@lms.test`; login `chi.sv@lms.test` sai mật khẩu	Cả hai 401, body giống hệt	1
A2	`GET /me` không token	401	2
A3	Token của Chi, sửa `sub` thành `u1`, giữ chữ ký cũ	401	1
A4	Token có header `alg: none`	401	1
A5	`TOKEN_TTL_SECONDS=1`, chờ 2 giây, gọi `/me`	401	1
A6	Soi mọi response	Không có `password`, `password_hash`, `passwordHash`	6
A7	Chi `GET /courses/c1/grades`	200 `[{"studentId":"u4","score":7.5}]`	4
A8	Chi `GET /courses/c2/grades`	403	4
A9	Chi `PUT /courses/c1/grades/u4 {"score":10}`	403	3, 4
A10	Bình `PUT /courses/c1/grades/u4 {"score":0}`	403	4
A11	Admin `PUT /courses/c1/grades/u4 {"score":10}`	403	3, 4

#	Thao tác	Kết quả đúng	Lớp
A12	An PUT c1/u4 với `score` là `11`, `-1`, `"10"`, `true`; và body `{"score":9,"courseId":"c2"}`	Cả 5 trường hợp 400	5
A13	An `PUT /courses/c1/grades/u6` `{"score":5}`	404	4
A14	An PUT c1/u4 `{"score":9}`, sau đó Chi GET c1	200; Chi thấy 9	—
A15	Gỡ `@require_role` khỏi route PUT, chạy lại A9–A11; gọi `update_grade(chi, "c1", "u4", 10)`	Vẫn 403; hàm ném `Forbidden`	4
A16	Thêm `GET /debug` không khai báo gì, gọi không token	401	2
A17	`create_app()` khi thiếu `JWT_SECRET`	`RuntimeError`	6
A18	Sai mật khẩu Dũng 5 lần, lần 6 nhập đúng	429	7
A19	Sau A10 và A14, đọc file `AUDIT_LOG_PATH`	2 dòng tương ứng, không có mật khẩu, token	8

6. Nộp bài

- Push trước khi hết giờ; commit sau giờ không được chấm.
- CI xanh trên commit cuối.
- Có `requirements.txt` và `.env.example`; không commit secret thật.